مقيد

شركة القيروان لنظم المعلومات

سياسة استخدام الذكاء الاصطناعي

سياسة تنظيمية · برنامج الالتزام بالضوابط الأساسية للأمن السيبراني

رقم الوثيقة	QIS-POL-002
الإصدار	٠,٦ (مسودة)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	مقيد
إشارة المشاركة	برتقالي · TLP:AMBER

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

معلومات السياسة

اسم السياسة	سياسة استخدام الذكاء الاصطناعي
رمز السياسة	QIS-POL-002
مالك السياسة	قائد الحوكمة والمخاطر والالتزام — نايف السالم
مُعِدّ السياسة	نايف السالم — قائد الحوكمة والمخاطر والالتزام
تاريخ بناء السياسة	٥ نوفمبر ٢٠٢٦م
إصدار السياسة	٠,٦ (مسودة)
الإجراءات التنفيذية	QIS-PRC-002 إجراءات استخدام الذكاء الاصطناعي

إشارة المشاركة (Traffic Light Protocol)

صُنّفت هذه السياسة وفق بروتوكول الإشارة الضوئية (TLP) المعتمد في وثائق الهيئة الوطنية للأمن السيبراني عند المستوى **برتقالي (TLP:AMBER)**، ولا يجوز تداولها خارج هذا النطاق دون موافقة مالك الوثيقة.

● **أحمر** TLP:RED	شخصي وسري للمستلم فقط: لا يجوز للمستلم مشاركتها مع أي فرد من داخل الجهة أو خارجها خارج النطاق المحدد للاستلام.
● **برتقالي** TLP:AMBER	**مشاركة محدودة: يجوز للمستلم مشاركتها داخل جهته مع الأشخاص المعنيين فقط، ومن يتطلب الأمر منهم اتخاذ إجراء بشأنها. — المستوى المعتمد لهذه الوثيقة**
● **أخضر** TLP:GREEN	مشاركة في نفس المجتمع: يجوز مشاركتها مع الجهة نفسها أو جهة ذات علاقة أو في القطاع نفسه، دون تبادلها أو نشرها عبر القنوات العامة.
● **أبيض** TLP:WHITE	غير محدود.

سجل التعديلات

النسخة	التاريخ	عُدّل بواسطة	أسباب التعديل
٠,١	٥ نوفمبر ٢٠٢٦م	نايف السالم	المسودة الأولى للسياسة والإجراء في وثيقة واحدة.
٠,٢	٩ نوفمبر ٢٠٢٦م	نايف السالم	إضافة وسوم أمن المعلومات: التصنيف في الرأس، والعلامة المائية، وإشارة المشاركة في التذييل.

النسخة	التاريخ	عُدّل بواسطة	أسباب التعديل
٠,٣	٩ نوفمبر ٢٠٢٦م	نايف السالم	إعادة بناء السياسة وفق القالب المعتمد لسياسات الشركة، وبناء البنود على إرشادات الأمن السيبراني للذكاء الاصطناعي (AICG-1:2026) وسياسة «الذكاء الاصطناعي أولاً»، ونقل الخطوات التنفيذية إلى الوثيقة المستقلة QIS-PRC-002.
٠,٤	٩ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الهوية البصرية الجديدة (الألوان والخطوط وصفحة الغلاف)، وتحسين قابلية القراءة، واعتماد مستويات إشارة المشاركة الأربعة المستخدمة في وثائق الهيئة الوطنية للأمن السيبراني.
٠,٥	١٠ نوفمبر ٢٠٢٦م	نايف السالم	تصحيح جدول سجل التغييرات (نُقل صف الإصدار ٠,٤ خطأً إلى جدول الاعتماد)، وتوسيط شارة التصنيف وتلوينها بلون مستواها، وتلوين العلامة المائية، واعتماد اسم الشركة «شركة القيروان لنظم المعلومات».
٠,٦	١١ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة.

اعتماد الوثيقة

الدور	المسمى الوظيفي	الاسم	التاريخ	التوقيع
المالك	قائد الحوكمة والمخاطر والالتزام	نايف السالم	—	—
المُراجِع	الرئيس التنفيذي للتقنية	ريم العتيبي	—	—
المُراجِع	رئيس تقديم الخدمات	سلطان الدوسري	—	—
المُراجِع	الرئيس التنفيذي للمالية (العقود والموارد البشرية)	ماجد القحطاني	—	—
المُصرِّح	رئيس اللجنة الإشرافية للأمن السيبراني	فيصل الحربي	—	—
المعتمِد	الرئيس التنفيذي	فيصل الحربي	—	—

جدول المراجعة

معدل المراجعة	تاريخ آخر مراجعة	تاريخ المراجعة القادمة
مرة كل ستة أشهر خلال السنة الأولى، ثم سنوياً	—	مايو ٢٠٢٧م

تصنيف السياسة

سري للغاية	تُصنّف السياسة «سري للغاية» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر جسيم لا يمكن تداركه أو إصلاحه.
سري	تُصنّف السياسة «سري» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر جسيم، وينطبق على المعلومات الحساسة التي تحدد طريقة عمل الشركة.
مقيد	**تُصنّف السياسة «مقيد» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر محدود، وينطبق على المعلومات التي لم تُعتمد للتداول العام خارج الشركة.**
عام	تُصنّف السياسة «عام» عندما لا يترتب على الوصول غير المصرح به إليها أو الإفصاح عن محتواها أي أثر على الشركة، وينطبق على الوثائق المعتمدة للنشر العام.

سرية السياسة

تعد هذه السياسة إحدى وثائق شركة القيروان لنظم المعلومات المصنفة «مقيد»، ويقتصر تداولها على منسوبي الشركة والجهات الحكومية المتعاقدة معها التي تحتاج إلى الاطلاع عليها ضمن تقييم الموردين، ولا يحق نشرها أو تعديلها أو نشر جزء منها لغير المصرح لهم. ويجوز منح صلاحية الاطلاع الجزئي أو الكلي لجهات أخرى لأغراض العمل بموافقة كتابية مسبقة من مالك السياسة، وفي هذه الحالة يلتزم من مُنح الصلاحية بالحفاظ على سرية ما ورد فيها وعدم إفشائه أو مشاركته دون موافقة كتابية مسبقة.

جدول المحتويات

١. المصطلحات والتعاريف

٢. المقدمة

٣. الغرض من السياسة

٤. نطاق التطبيق

٥. الالتزام بالسياسة

٦. الأدوار والمسؤوليات

٦,١ مصفوفة المسؤوليات (RACI) · ٦,٢ إسناد حوكمة الذكاء الاصطناعي

٧. المبادئ

٧,١ الشفافية · ٧,٢ العدالة · ٧,٣ الخصوصية · ٧,٤ الأصول

٨. بنود السياسة — إرشادات الأمن السيبراني للذكاء الاصطناعي (AICG-1:2026)

٩. المواءمة مع سياسة «الذكاء الاصطناعي أولاً»

١٠. مؤشرات الأداء الرئيسية (KPIs)

١١. مؤشرات أداء المخاطر (KRIs)

١٢. عواقب عدم الامتثال

١٣. آلية التواصل

١٤. المراجعة وتحديث السياسة

١٥. المراجع

مقيد

١. المصطلحات والتعاريف

المصطلح	التعريف
الذكاء الاصطناعي (AI)	تقنيات وأنظمة حاسوبية قادرة على محاكاة الذكاء البشري، مثل التعلم والتحليل واتخاذ القرار، لتنفيذ مهام محددة.
أداة ذكاء اصطناعي معتمدة	أداة مدرجة في سجل أدوات الذكاء الاصطناعي المعتمدة بعد تقييمها وفق الإجراء الأول في QIS-PRC-002، مع تحديد الاستخدامات المسموح بها وأعلى تصنيف بيانات يجوز إدخاله.
بيانات العملاء	أي بيانات أو شيفرات أو وثائق أو إعدادات تعود للعملاء من (أ) إلى (و)، أياً كان تصنيفها.
البيانات الحساسة	البيانات التي تتطلب مستوى عالياً من الحماية، مثل البيانات الشخصية وبيانات المواطنين والبيانات المصنفة، والتي قد يؤدي تسريبها إلى ضرر للأفراد أو للشركة أو لعملائها.
الأوامر (Prompts)	النصوص والملفات التي يُدخلها المستخدم إلى أداة الذكاء الاصطناعي.
حقن الأوامر (Prompt Injection)	محاولة توجيه نموذج الذكاء الاصطناعي عبر مدخلات مصمَّمة لتجاوز تعليماته أو كشف بيانات.
وكيل الذكاء الاصطناعي (AI Agent)	نظام ذكاء اصطناعي ينفذ إجراءات أو يستدعي أدوات وخدمات نيابة عن المستخدم بدرجة من الاستقلالية.
الإشراف البشري	مراجعة شخص مختص لمخرجات الذكاء الاصطناعي ومتابعة قراراته لضمان دقتها ومنع الأخطاء والتأكد من الالتزام بالضوابط.
الشفافية	مبدأ يضمن وضوح كيفية عمل أنظمة الذكاء الاصطناعي وإمكانية فهم مخرجاتها، والإفصاح عن استخدامها عند الحاجة.
العدالة	مبدأ يضمن تعامل أنظمة الذكاء الاصطناعي مع جميع المستفيدين دون تحيز أو تمييز غير مبرر.
الخصوصية	مبدأ يهدف إلى حماية البيانات الشخصية من الوصول أو الاستخدام غير المصرح به، واستخدامها للأغراض المشروعة فقط.
الحد الأدنى من الصلاحيات (Least Privilege)	مبدأ يقضي بمنح المستخدمين والأنظمة والوكلاء الحد الأدنى من الصلاحيات اللازمة لأداء مهامهم فقط.
منع تسرب البيانات (DLP)	تقنية تهدف إلى منع تسرب البيانات الحساسة أو فقدانها أو الوصول غير المصرح به إليها.
الثغرات الأمنية	نقاط ضعف في الأنظمة أو التطبيقات أو البنية التحتية قد تُستغل لتهديد أمن المعلومات.

المصطلح	التعريف
إدارة استمرارية الأعمال	إطار إداري يضمن استمرار العمليات الحيوية أثناء أي انقطاع وبعده، واستعادتها ضمن وقت مقبول.
مؤشر الأداء الرئيسي (KPI)	مقياس يُستخدم لتقييم مدى تحقيق الأهداف المحددة وقياس أداء العمليات والضوابط.
مؤشر المخاطر الرئيسي (KRI)	مقياس يُستخدم لمراقبة مستوى المخاطر عبر الإشارة المبكرة إلى اقترابها من حدود الرغبة في المخاطر.
نظام حماية البيانات الشخصية (PDPL)	النظام الذي ينظم جمع البيانات الشخصية ومعالجتها وتخزينها ومشاركتها في المملكة، ولائحته التنفيذية.
السياسة	وثيقة رسمية معتمدة تتضمن المبادئ والقواعد التي تنظم عمل الشركة، وتحدد الإطار العام للقرارات والالتزام.
الإجراء	وثيقة تنفيذية منبثقة من السياسة تحدد خطوات العمل ومالكها ومخرجاتها ومددها والسجلات الواجب الاحتفاظ بها.

٢. المقدمة

تقدم شركة القيروان لنظم المعلومات خدمات تقنية مُدارة واستضافة وتطوير برمجيات لجهات حكومية، ويتزايد استخدام موظفيها لأدوات الذكاء الاصطناعي في كتابة الشيفرات، وإعداد الوثائق، وتحليل البيانات. وتوفر هذه الأدوات فرصاً حقيقية لرفع الكفاءة وجودة المخرجات، غير أنها تحمل مخاطر خاصة على بيانات العملاء الحكوميين وأنظمتهم، منها تسريب البيانات عبر الأوامر، وإدخال شيفرات غير آمنة إلى أنظمة العملاء، والاعتماد على مخرجات غير دقيقة. وتأتي هذه السياسة لتحديد الإطار العام لاستخدام الذكاء الاصطناعي في الشركة، بما يحمي بيانات العملاء ويعزز الاستخدام المسؤول، ويلتزم بالأنظمة الوطنية ومتطلبات الهيئة الوطنية للأمن السيبراني ونظام حماية البيانات الشخصية.

٣. الغرض من السياسة

تهدف هذه السياسة إلى تنظيم استخدام تقنيات الذكاء الاصطناعي في الشركة وفي الأنظمة التي تطورها أو تستضيفها لعملائها، بما يضمن الاستخدام الآمن والمسؤول، وحماية البيانات والمعلومات، والحد من المخاطر المرتبطة بهذه التقنيات، مع رفع الكفاءة التشغيلية والالتزام بالأنظمة واللوائح الوطنية ذات العلاقة.

٤. نطاق التطبيق

- جميع موظفي الشركة والمتعاقدين معها الذين يستخدمون أدوات الذكاء الاصطناعي في أعمال الشركة أو أعمال العملاء.
- جميع أنظمة وأدوات ونماذج الذكاء الاصطناعي المستخدمة في الشركة، بما فيها المساعدات البرمجية وأدوات الذكاء الاصطناعي التوليدي.
- مزايا الذكاء الاصطناعي التي تبنيها الشركة أو تدمجها في الأنظمة التي تطورها أو تستضيفها للعملاء.
- مزودو أدوات وخدمات الذكاء الاصطناعي الذين تتعامل معهم الشركة.
- جميع مراحل دورة حياة الذكاء الاصطناعي: الطلب، والتطوير، والاستخدام، والمعالجة، والتخزين، والمشاركة، والإيقاف.

٥. الالتزام بالسياسة

يجب على قائد الحوكمة والمخاطر والالتزام التأكد من التزام الشركة بهذه السياسة، وتلتزم جميع الإدارات المعنية بتطبيق ما ورد فيها. وتُنفَّذ بنود هذه السياسة عبر الإجراءات الواردة في الوثيقة QIS-PRC-002.

٦. الأدوار والمسؤوليات

الدور	المسؤوليات
الرئيس التنفيذي	يعتمد السياسة ويضمن مواءمتها مع الأهداف الاستراتيجية للشركة، ويتخذ القرارات العليا في الحالات الحرجة، ويعتمد إدخال مزايا الذكاء الاصطناعي في أنظمة العملاء.
اللجنة الإشرافية للأمن السيبراني	تصادق على السياسة، وتعتمد حالات الاستخدام عالية التأثير، وتقبل المخاطر المتبقية، وتتابع تقارير الالتزام الربعية.
قائد الحوكمة والمخاطر والالتزام	يكتب سياسات الذكاء الاصطناعي ويراجعها، ويدير سجل الأدوات المعتمدة وسجل مخاطر الذكاء الاصطناعي، ويقيّم الالتزام ويصعّد المخالفات، ويتولى مهام مسؤول حماية البيانات الشخصية.
العمليات والهندسة الأمنية	تقيّم مخاطر الأمن السيبراني لأنظمة الذكاء الاصطناعي وتختبرها، وتراقب السجلات عبر مركز العمليات الأمنية المُدار، وتقود الاستجابة للحوادث.
الرئيس التنفيذي للتقنية	يشرف على تشغيل أدوات الذكاء الاصطناعي وبيئاتها، وينفذ الصلاحيات والإعدادات الأمنية والتسجيل، ويدعم الاستعادة.

الدور	المسؤوليات
فريق التطوير	يطبق متطلبات التطوير الآمن، ويراجع الشيفرات المولدة بالذكاء الاصطناعي ويختبرها قبل دمجها.
رئيس تقديم الخدمات	ينسق مع العملاء في كل ما يتعلق باستخدام الذكاء الاصطناعي في بياناتهم وأنظمتهم، ويحصل على موافقاتهم المكتوبة.
الرئيس التنفيذي للمالية	يضمّن بنود الذكاء الاصطناعي في عقود الموظفين والمزودين، ويتابع الإجراءات التأديبية مع الموارد البشرية.
جميع الموظفين والمتعاقدين	يلتزمون بالسياسة، ويستخدمون الأدوات المعتمدة فقط ضمن الاستخدامات المسموح بها، ويبلغون فوراً عن أي حادثة.

٦٫١ مصفوفة المسؤوليات (RACI)

التنفيذي: الرئيس التنفيذي · اللجنة: اللجنة الإشرافية للأمن السيبراني · الحوكمة: الحوكمة والمخاطر والالتزام · الأمن: العمليات والهندسة الأمنية · التقنية: الرئيس التنفيذي للتقنية · التطوير: فريق التطوير · الخدمات: تقديم الخدمات

R — المنفذ (Responsible) · A — المسؤول النهائي (Accountable) · C — يُستشار (Consulted) · I — يُبلَّغ (Informed)

النشاط	التنفيذي	اللجنة	الحوكمة	الأمن	التقنية	التطوير	الخدمات
اعتماد السياسة وتحديثاتها	A	C	R	C	C	I	I
اعتماد أداة ذكاء اصطناعي جديدة	I	A	R	C	C	I	I
إدارة سجل الأدوات وحالات الاستخدام	I	I	A/R	C	C	I	I
تصنيف البيانات قبل استخدامها	I	I	A	C	R	C	C
إدخال ميزة ذكاء اصطناعي في نظام عميل	A	C	R	C	R	R	C
إدارة الصلاحيات والوصول	I	I	C	A	R	I	I
الاستجابة لحوادث الذكاء الاصطناعي	I	I	C	A/R	R	C	C
قياس المؤشرات (KPIs / KRIs)	I	C	A/R	C	C	I	I
التدريب والتوعية	I	I	A/R	C	I	I	I

النشاط	التنفيذي	اللجنة	الحوكمة	الأمن	التقنية	التطوير	الخدمات
اختبار خطط التعافي والاستمرارية	**I**	**I**	**C**	**A**	**R**	**I**	**C**

٦٫٢ إسناد حوكمة الذكاء الاصطناعي

بند مضاف — شركة القيروان لنظم المعلومات

لا يرد هذا البند ضمن الوثائق المرجعية الخارجية، وقد أُضيف لأن الشركة لا تملك وحدة مستقلة للذكاء الاصطناعي، فيُسند تطبيق السياسة إلى الوحدات القائمة وفق ميثاق الأمن السيبراني QIS-CHR-001.

QIS-ORG-1	تُسند حوكمة الذكاء الاصطناعي إلى وحدة الحوكمة والمخاطر والالتزام ضمن إدارة الأمن السيبراني، وتشمل صياغة السياسات، وإدارة سجل الأدوات المعتمدة وسجل المخاطر، وتقييم الالتزام، ورفع التقارير إلى اللجنة الإشرافية.
QIS-ORG-2	يتولى الرئيس التنفيذي للتقنية تشغيل أدوات الذكاء الاصطناعي وبيئاتها، ويتولى فريق التطوير تطبيق متطلبات التطوير الآمن.
QIS-ORG-3	يُشترط الفصل بين الجهة المنفذة (التقنية والتطوير) والجهة المقيِّمة (الحوكمة والمخاطر والالتزام)؛ بما يمنع تعارض المصالح في اعتماد الأدوات وحالات الاستخدام وتقييم الالتزام.
QIS-ORG-4	تُحدَّث مصفوفة المسؤوليات (RACI) عند تعيين رئيس إدارة الأمن السيبراني وفق خطة الانتقال في QIS-CHR-001، ويُصدر تحديث لهذه السياسة يوثق ذلك.

٧. المبادئ

٧٫١ الشفافية

يجب الإفصاح عن استخدام الذكاء الاصطناعي للعميل متى اشترط العقد ذلك أو كان المخرج موجهاً إلى المواطنين، مع إمكانية تتبع المخرجات وفهم الأساس الذي بُنيت عليه.

٧٫٢ العدالة

يجب ألا تُستخدم مزايا الذكاء الاصطناعي في قرارات تمس المواطنين دون اختبار التحيز وموافقة العميل، مع ضمان معاملة جميع المستفيدين بشكل متساوٍ.

٧٫٣ الخصوصية

يجب حماية خصوصية البيانات عند استخدام الذكاء الاصطناعي، وعدم إدخال بيانات العملاء أو البيانات الشخصية في أدوات غير معتمدة لها، وعدم استخدامها في تدريب أي نموذج.

٧,٤ الأصول

يجب تسجيل كل أداة ونموذج ومفتاح واجهة برمجة ضمن سجل الأصول، وإخطار الإدارات المعنية عند أي تحديث عليها.

وتتوافق هذه المبادئ مع مبادئ أخلاقيات الذكاء الاصطناعي الصادرة عن الهيئة السعودية للبيانات والذكاء الاصطناعي.

٨. بنود السياسة — إرشادات الأمن السيبراني للذكاء الاصطناعي

تلتزم الشركة بتطبيق إرشادات الأمن السيبراني للذكاء الاصطناعي (AICG-1:2026) الصادرة عن الهيئة الوطنية للأمن السيبراني، والمكونة من أربعة مكونات أساسية تتفرع منها خمسة عشر مكوناً فرعياً، وتضم اثنين وأربعين ضابطاً. وترد فيما يلي بأرقامها المرجعية ونصوصها، وقد أُضيفت تحت كل مكوّن فرعي متطلبات تنفيذية خاصة بالشركة تحمل الرمز QIS، تفصّل آليات التطبيق دون أن تتقاطع مع نصوص الضوابط.

الرقم	المكون الأساسي	المكونات الفرعية	الضوابط
١	حوكمة الأمن السيبراني	٤	١٣
٢	تعزيز الأمن السيبراني	٩	٢٤
٣	صمود الأمن السيبراني	١	١
٤	الأمن السيبراني المتعلق بالأطراف الخارجية	١	٤

١ حوكمة الأمن السيبراني (Cybersecurity Governance)

١-١ إدارة مخاطر الأمن السيبراني (Cybersecurity Risk Management)

الهدف: ضمان إدارة مخاطر الأمن السيبراني للذكاء الاصطناعي وفق منهجية واضحة؛ لحماية الأصول المعلوماتية والتقنية للجهة، وذلك وفقاً للسياسات والإجراءات التنظيمية، والأنظمة والتشريعات ذات العلاقة.

الرقم	الضوابط
١-١-١	تحديد ممارسات إدارة مخاطر الأمن السيبراني لجميع مراحل دورة حياة أنظمة الذكاء الاصطناعي، وتوثيقها واعتمادها، ومن ثم تنفيذها.

الرقم	الضوابط
١-١-٢	إجراء تقييم لمخاطر الأمن السيبراني؛ بهدف تصنيف وكلاء أنظمة الذكاء الاصطناعي وفقاً للتأثير المحتمل، واحتمالية الحدوث، وإمكانية التراجع، وتطبيق تدابير الأمن السيبراني المناسبة.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-1-1-1	تُقيَّم مخاطر الذكاء الاصطناعي وفق منهجية إدارة المخاطر QIS-RMM-001، وتُسجَّل في سجل المخاطر QIS-RR-001 ضمن فئة مستقلة، وتُراجع كل ثلاثة أشهر.
QIS-1-1-2	يُوثَّق قبول المخاطر المتبقية من مالك الخطر وفق صلاحيات القبول في QIS-RMM-001 قبل الإطلاق في بيئة الإنتاج أو في نظام أي عميل.
QIS-1-1-3	يُعاد تقييم المخاطر عند أي تغيير جوهري في النموذج أو مصدر البيانات أو نطاق الاستخدام، أو خلال اثني عشر شهراً من آخر تقييم، أيهما أقرب.

١-٢ الأمن السيبراني ضمن إدارة المشاريع المعلوماتية والتقنية (Cybersecurity in Information and Technology Project Management)

الهدف: ضمان تضمين متطلبات الأمن السيبراني للذكاء الاصطناعي في ممارسات إدارة المشاريع المعلوماتية والتقنية خلال كافة مراحل دورة حياة أنظمة الذكاء الاصطناعي.

الرقم	الضوابط
١-٢-١	تطبيق ممارسات التصميم الآمن (Security by Design)، وتحديد إجراءات وتنفيذها لتأمين تطوير الذكاء الاصطناعي وتشغيله، بدءاً من تحديد متطلبات الأمن السيبراني، والحصول على البيانات من مصادر موثوقة وآمنة، وتدريب النماذج وضبطها، وإعداد إدارة الأوامر (Prompt Configurations)، وتقييم النماذج ونشرها وتشغيلها وصيانتها، وانتهاءً بإيقافها والتخلص الآمن منها.
٢-٢-١	التعامل مع البيانات المسترجعة من الأدوات الخارجية، أو قواعد الذاكرة، أو واجهات برمجة التطبيقات (APIs) التابعة لأطراف خارجية باعتبارها غير موثوقة، وتطبيق عمليات تحقق وتطهير على أي بيانات تُدخل في نافذة السياق (Context Window)؛ لمنع تنفيذ الأوامر الخبيثة المتخفية في صورة بيانات.
٣-٢-١	تجنب إعادة تدريب النماذج أو التعلم العشوائي في بيئة التشغيل الفعلية دون وضع ضوابط مباشرة ووجود المبررات اللازمة، على أن يُجرى تقييم لمخاطر الأمن السيبراني.
٤-٢-١	تقييم قدرات وصمود الأمن السيبراني لوكلاء الذكاء الاصطناعي خلال تطويرها وتشغيلها.
٥-٢-١	إجراء مراجعات واختبارات للأمن السيبراني، والاعتماد الرسمي بصورة منهجية لجميع الشيفرات البرمجية المولدة بالذكاء الاصطناعي؛ لمعالجة مخاطر الأمن السيبراني قبل استخدامها في بيئات التطوير أو التكامل أو الإنتاج.
٦-٢-١	تحديد إجراءات الموافقة على مشاريع أنظمة الذكاء الاصطناعي ذات التأثير العالي وتنفيذها قبل نشرها في بيئة الإنتاج، مع ضمان تقييم مخاطر الأمن السيبراني ومعالجتها.

الرقم	الضوابط
١-٢-٧	تطبيق استقلالية وكيل الذكاء الاصطناعي بشكل متدرج، مع ضمان الإشراف البشري المستمر لمراقبة القرارات والإجراءات المتعلقة بالأمن السيبراني وفهمها.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-1-2-1	تُعتمد بوابة مراجعة أمنية إلزامية في نهاية كل مرحلة من مراحل مشاريع العملاء التي تتضمن الذكاء الاصطناعي في نطاقها أو في أدوات تطويرها، مع توثيق قرار الموافقة أو الرفض ومبرراته.
QIS-1-2-2	تمر كل شيفرة مولدة بالذكاء الاصطناعي بمراجعة الأقران والفحص الأمني وفحص الاعتماديات في خط البناء قبل دمجها في مستودعات العملاء، ولا تُدمج دونها.
QIS-1-2-3	تُفصل بيئات التطوير والاختبار والإنتاج، ويُمنع استخدام بيانات العملاء الفعلية في بيئات التطوير إلا بعد إخفاء الهوية والحصول على موافقة العميل.

١-٣ الأمن السيبراني المتعلق بالموارد البشرية (Cybersecurity in Human Resources)

الهدف: ضمان إدارة مخاطر الأمن السيبراني ومتطلباته للذكاء الاصطناعي المتعلقة بالعاملين (موظفين ومتعاقدين) بفعالية قبل عملهم وأثناءه وعند انتهائه، وفقاً للسياسات والإجراءات التنظيمية والمتطلبات التشريعية ذات العلاقة.

الرقم	الضوابط
١-٣-١	إجراء المسح الأمني للعاملين الذين لديهم إمكانية الوصول لمكونات أنظمة الذكاء الاصطناعي الداخلية، أو الذين لديهم صلاحيات الوصول الهامة والحساسة لبيئات تشغيل الذكاء الاصطناعي أو غيرها من مهام الذكاء الاصطناعي ذات المخاطر المرتفعة.
٢-٣-١	ضمان الالتزام بالسرية والاستخدام المقبول والتعامل الآمن لجميع العاملين الذين قد تكشف أدوارهم عن بيانات حساسة، أو عن الأوامر أو المخرجات أو الإعدادات لأنظمة الذكاء الاصطناعي.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-1-3-1	تُضمَّن بنود الاستخدام المقبول للذكاء الاصطناعي في عقود الموظفين والمتعاقدين وإقرارات السرية، مع توقيع إقرار سنوي.
QIS-1-3-2	تُلغى جميع الصلاحيات المرتبطة بالذكاء الاصطناعي فور انتهاء العلاقة التعاقدية أو تغيير الدور الوظيفي، بما يشمل حسابات الأدوات الخارجية ومفاتيح واجهات البرمجة.

١-٤ برنامج التوعية والتدريب بالأمن السيبراني (Cybersecurity Awareness and Training Program)

الهدف: ضمان تلقي المختصين والمستخدمين التوعية والتدريب الخاص بالأمن السيبراني للذكاء الاصطناعي بما يتناسب مع أدوارهم ومخاطر الأمن السيبراني المرتبطة بأنظمة الذكاء الاصطناعي.

الرقم	الضوابط
١-٤-١	تضمين متطلبات الأمن السيبراني للذكاء الاصطناعي في برامج تدريب العاملين المشاركين في تطوير أنظمة الذكاء الاصطناعي أو إعدادها أو تشغيلها، بما يشمل: التصميم الآمن للأوامر والأدوات، والتعامل مع المخرجات، والإبلاغ عن الحوادث، والتعامل الآمن مع البيانات الحساسة في الأوامر والملفات المرفوعة، والتعرف على التهديدات المرتبطة بالذكاء الاصطناعي مثل حقن الأوامر وتسريب البيانات، والتحقق من المخرجات.
١-٤-٢	تضمين التوعية بالأمن السيبراني لأنظمة الذكاء الاصطناعي ضمن برنامج التوعية الشامل للأمن السيبراني في الجهة، ويشمل ذلك: الاستخدام الآمن للأوامر وتجنب إدخال معلومات حساسة فيها، ومخاطر البرمجيات المولدة بالذكاء الاصطناعي وضوابط مراجعتها واختبارها قبل الاستخدام.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-1-4-1	يُكمل كل موظف ومتعاقد تدريباً قصيراً على هذه السياسة قبل منحه أي أداة معتمدة، وخلال ثلاثين يوماً من مباشرة العمل للملتحقين الجدد، مع تدريب تنشيطي سنوي.
QIS-1-4-2	تُنفذ تمارين محاكاة لحقن الأوامر وتسريب البيانات لفرق التطوير والخدمات المُدارة، وتُرفع نتائجها إلى اللجنة الإشرافية.
QIS-1-4-3	يُتاح مرجع داخلي محدَّث يوضح الأدوات المعتمدة، والبيانات المسموح بإدخالها في كل منها، وأمثلة الاستخدام المسموح وغير المسموح.

٢ تعزيز الأمن السيبراني (Cybersecurity Defense)

١-٢ إدارة الأصول (Asset Management)

الهدف: ضمان امتلاك الجهة سجلاً دقيقاً ومفصلاً للأصول المعلوماتية والتقنية المرتبطة بالذكاء الاصطناعي، بما يدعم متطلبات الأمن السيبراني والمتطلبات التشغيلية، ويحافظ على سرية تلك الأصول وسلامتها وتوافرها.

الرقم	الضوابط
١-١-٢	إنشاء قائمة جرد للأصول الخاصة بجميع مكونات نظام الذكاء الاصطناعي، وتحديثها بشكل مستمر.
٢-١-٢	تحديد مالك الأصول وحالة دورة حياتها لجميع مكونات نظام الذكاء الاصطناعي، بما في ذلك الأصول التجريبية، وأصول ما قبل النشر، وأصول بيئة الإنتاج، والأصول المقيدة، والأصول المنتهي استخدامها، وكذلك الخدمات والإعدادات.
٣-١-٢	تحديد وتنفيذ الإجراءات المتعلقة بالأصول والمكونات بعد انتهاء استخدام أنظمة الذكاء الاصطناعي ولمرحلة ما بعد التشغيل، مثل إجراءات التخلص الآمن منها.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-1-1	يُربط سجل أدوات الذكاء الاصطناعي المعتمدة بسجل الأصول QIS-AST-001، ويُحدَّث خلال خمسة أيام عمل من أي إضافة أو تغيير أو إيقاف.
QIS-2-1-2	يُحدد لكل أصل مالك من جهة الأعمال ومالك تقني، ويُربط بالعملاء الذين يخدمهم.
QIS-2-1-3	تُوثَّق سلسلة إمداد كل نموذج أو مكتبة (المصدر، والترخيص، والاعتماديات) ضمن قائمة مكونات أنظمة الذكاء الاصطناعي (AI-BOM).

٢-٢ إدارة هويات الدخول والصلاحيات (Identity and Access Management)

الهدف: ضمان الوصول المنطقي الآمن والمقيد إلى الأصول المعلوماتية والتقنية المرتبطة بالذكاء الاصطناعي، لمنع الوصول غير المشروع، وقصر صلاحيات الوصول على المستخدمين والخدمات ووكلاء الذكاء الاصطناعي المصرح لهم فحسب، وعند الحاجة لإنجاز المهام المسندة إليهم.

الرقم	الضوابط
٢-٢-١	تحديد الصلاحيات وسياسات التصاريح وفقاً لمهمات المستخدم لحسابات المستخدمين البشريين وحسابات الخدمة وحسابات وكلاء الذكاء الاصطناعي، وضمان تطبيق مبادئ فصل المهام، والحد الأدنى من الصلاحيات والامتيازات، والحاجة إلى المعرفة والاستخدام.
٢-٢-٢	إجراء المراجعة الدورية للهويات وصلاحيات الوصول والرموز وحسابات الخدمة المستخدمة من قبل أنظمة الذكاء الاصطناعي.
٢-٢-٣	وجود القدرة على التحكم في الصلاحيات بما يخفف المخاطر المتعلقة بالذكاء الاصطناعي، بما في ذلك تحديد المعدل (Rate Limiting) وحدود الاستخدام (Usage Threshold) وآليات أخرى؛ للتخفيف من مخاطر استخراج النماذج وتسريب البيانات.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-2-1	تُشترط المصادقة متعددة العوامل والدخول الموحد لكل وصول إلى أدوات الذكاء الاصطناعي المعتمدة، ولكل وصول إداري إلى مكوناتها.
QIS-2-2-2	تُدار مفاتيح واجهات البرمجة عبر خزنة الأسرار: الإصدار، والتدوير كل تسعين يوماً، والإبطال الفوري عند الاشتباه، ويُمنع تخزينها في الشيفرات أو المستودعات.
QIS-2-2-3	يُربط كل حساب لوكيل ذكاء اصطناعي بمالك بشري مسؤول، ويُمنع استخدام الحسابات المشتركة أو مجهولة المالك.

٢-٣ إدارة أمن الشبكات (Network Security Management)

الهدف: ضمان الأمن السيبراني لمسارات الشبكة والواجهات والاتصالات المستخدمة في أنظمة الذكاء الاصطناعي، بما في ذلك حركة البيانات المتعلقة بالتدريب والضبط والاسترجاع والاستدلال، والاتصالات مع الأدوات والخدمات الخارجية.

الرقم	الضوابط
٢-٣-١	عزل شبكة المكونات الداخلية لأنظمة الذكاء الاصطناعي عن المكونات الخارجية، وتقييد البروتوكولات والمنافذ والوجهات ومسارات الخروج (Egress Path) بالمتطلبات المعتمدة فحسب؛ لفرض حدود الثقة واكتشاف الحالات غير العادية.
٢-٣-٢	عزل شبكة المكونات الخارجية لأنظمة الذكاء الاصطناعي، وتقييد الوصول والاتصالات إليها وفق الحاجة التشغيلية فحسب، مع تطبيق الضوابط المناسبة لحماية الأنظمة المواجهة للإنترنت، وتقليل سطح الهجوم، واكتشاف الحالات غير العادية.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-3-1	تُعتمد قائمة سماح بوجهات خدمات الذكاء الاصطناعي المعتمدة، وتُحجب ما عداها افتراضياً على شبكة الشركة وأجهزتها.
QIS-2-3-2	لا تتصل أداة الإدارة عن بُعد ولا شبكات العملاء بأي خدمة ذكاء اصطناعي خارجية إلا بموافقة العميل المكتوبة.

٢-٤ حماية البيانات والمعلومات (Data and Information Protection)

الهدف: ضمان حماية البيانات والمعلومات التي تستخدمها أنظمة الذكاء الاصطناعي أو تنتجها أو ترتبط بها بأي صورة، على امتداد دورة حياتها.

الرقم	الضوابط
٢-٤-١	حماية سرية بيانات مكونات أنظمة الذكاء الاصطناعي وسلامتها، ويشمل ذلك بيانات التدريب والتقييم وأوزان النموذج والأوامر والتضمينات والسجلات والسياقات والمخرجات، في حالة التخزين وأثناء النقل وأثناء المعالجة، وتقييد الوصول إليها والكشف عنها بحيث يقتصر على المصرح لهم فحسب.
٢-٤-٢	حماية البيانات المصنفة ضمن أنظمة الذكاء الاصطناعي في حالة التخزين وأثناء النقل وأثناء المعالجة، وفقاً لتصنيفها حسب المتطلبات التشريعية والتنظيمية ذات العلاقة.
٢-٤-٣	حماية مكونات ذاكرة الذكاء الاصطناعي من التعديل غير المشروع، والتحقق من صحة المحتوى المخزن؛ لمنع تسميم الذاكرة والتلاعب بها.
٢-٤-٤	تحديد ضوابط حماية (Guardrails) للكشف عن المدخلات الخبيثة وتنفيذها، وتحديد الإجراءات غير المصرح بها، والكشف عن المعلومات الحساسة وأي تهديدات أخرى، وضمان إجراء الاختبارات قبل النشر وبعد التغييرات الجوهرية.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-4-1	يُحدد لكل أداة معتمدة أعلى تصنيف بيانات يجوز إدخاله. ولا تُدخل بيانات العملاء في أي أداة إلا بموافقة العميل المكتوبة وبأداة مستضافة داخل المملكة، ولا تُدخل البيانات المصنفة «مقيد» فما فوق أو كلمات المرور والمفاتيح في أي أداة دون استثناء.
QIS-2-4-2	يُتفق تعاقدياً مع مزودي أدوات الذكاء الاصطناعي على عدم استخدام بيانات الشركة أو عملائها في تدريب نماذجهم، ويُوثَّق ذلك في اتفاقية الخدمة.
QIS-2-4-3	تُطبق أدوات منع تسرب البيانات على حركة البيانات المتجهة إلى خدمات الذكاء الاصطناعي، وتُراجع تنبيهاتها شهرياً.
QIS-2-4-4	تُحدد مدد الاحتفاظ بسجلات الأوامر والمخرجات، ويُتخلص منها بأمان عند انتهاء المدة.

٢-٥ إدارة النسخ الاحتياطية (Backup and Recovery Management)

الهدف: ضمان وجود ترتيبات آمنة للنسخ الاحتياطية والاستعادة والرجوع إلى الإصدارات السابقة (Rollback) لأنظمة الذكاء الاصطناعي.

الرقم	الضوابط
٢-٥-١	تطبيق آليات آمنة للنسخ الاحتياطي والاستعادة لضمان توافر أنظمة الذكاء الاصطناعي وموثوقيتها، مع ضمان استعادتها ضمن الوقت المحدد.
٢-٥-٢	اختبار إجراءات النسخ الاحتياطي والاستعادة والرجوع إلى الإصدارات السابقة لأنظمة الذكاء الاصطناعي بشكل دوري.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-5-1	تُضمَّن ملفات الإعدادات ومكتبات الأوامر ومصادر المعرفة لمزايا الذكاء الاصطناعي في أنظمة العملاء ضمن نطاق النسخ الاحتياطي المعتمد في QIS-BCP-001.
QIS-2-5-2	يُحتفظ بنسخة قابلة للاسترجاع من آخر إصدارين معتمدين لكل ميزة ذكاء اصطناعي قيد التشغيل؛ لتمكين الرجوع السريع عند تدهور الأداء أو وقوع حادثة.

٢-٦ إدارة الثغرات (Vulnerability Management)

الهدف: ضمان تحديد الثغرات الأمنية التي تؤثر على نماذج الذكاء الاصطناعي والتطبيقات والبنية التحتية والاعتماديات وعمليات التكامل، وتقييمها ومعالجتها والإبلاغ عنها في الوقت المناسب.

الرقم	الضوابط
٢-٦-١	تحديد الثغرات الأمنية في أنظمة الذكاء الاصطناعي وتتبعها ومعالجتها.

الرقم	الضوابط
٢-٦-٢	التواصل والاشتراك مع خدمات المعلومات الاستباقية للثغرات والتهديدات على أنظمة الذكاء الاصطناعي، مع مراقبة التوصيات الأمنية الصادرة من المطورين، وتحديثات حالة الخدمات، وتنبيهات الأمن السيبراني.
٣-٦-٢	تعطيل خصائص الذكاء الاصطناعي أو تقييدها عند اكتشاف ثغرة أمن سيبراني إلى أن يتم ضمان المعالجة والتحقق منها.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-6-1	تُعالج الثغرات وفق المدد القصوى المحددة في سياسة إدارة الثغرات للشركة حسب خطورتها، ويُصعَّد تجاوز المدة إلى مالك السياسة.
QIS-2-6-2	تُفحص اعتماديات مكتبات الذكاء الاصطناعي مفتوحة المصدر آلياً في خط البناء، ويُمنع الدمج عند اكتشاف ثغرات حرجة.

٢-٧ اختبار الاختراق (Penetration Testing)

الهدف: تقييم مدى فعالية إرشادات الأمن السيبراني التي تحمي أنظمة الذكاء الاصطناعي، من خلال محاكاة أساليب الهجوم والتهديد ذات الصلة؛ لتحديد الثغرات القابلة للاستغلال والأخطاء في الإعدادات ونقاط الضعف قبل الإطلاق وبعده، بما يتناسب مع مستوى المخاطر وتعقيد الأنظمة ومدى تعرضها للتهديدات.

الرقم	الضوابط
١-٧-٢	إجراء اختبارات اختراق لمكونات نظام الذكاء الاصطناعي، واختبارات اختراق مخصصة للذكاء الاصطناعي قبل النشر وبشكل دوري، بما يضمن اختبار المخرجات وأداء النظام.
٢-٧-٢	إجراء اختبارات لأنظمة الذكاء الاصطناعي بطرق مختلفة مثل اختبارات الفريق الأحمر (Red-teaming)، وتقييم مقاومة الهجمات (Adversarial Evaluation)، والتحقق من صحة إجراءات التجاوز البشري (Human Override).
٣-٧-٢	معالجة الملاحظات والثغرات المكتشفة من خلال اختبارات وتقييمات الأمن السيبراني، وتحديد آليات التحصين المناسبة.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-7-1	يُجرى اختبار اختراق قبل إطلاق أي ميزة ذكاء اصطناعي في نظام عميل، ثم سنوياً على الأقل وعند كل تغيير جوهري.
QIS-2-7-2	يُسند الاختبار إلى فريق مستقل عن فريق التطوير، ويُعاد الاختبار للتحقق من المعالجة قبل إغلاق الملاحظات.

٨-٢ إدارة سجلات الأحداث ومراقبة الأمن السيبراني (Cybersecurity Event Logs and Monitoring Management)

الهدف: ضمان تغطية قدرات التسجيل والمراقبة والكشف عن الأحداث والإجراءات والتغييرات والسلوكيات غير الطبيعية الخاصة بالذكاء الاصطناعي؛ لدعم الالتزام والاستجابة للحوادث والتحقق المستمر.

الرقم	الضوابط
٢-٨-١	تسجيل أحداث الأمن السيبراني على مكونات أنظمة الذكاء الاصطناعي ومراقبتها، بما في ذلك أحداث هويات الدخول والصلاحيات، والأحداث الهامة والحساسة على الأصول، والوصول إلى مجموعات البيانات ومصادر المعرفة، والتغيير على الإعدادات، وتفعيل المكونات والأدوات.
٢-٨-٢	تسجيل أحداث الأمن السيبراني المرتبطة بالإجراءات التي تتخذها أنظمة الذكاء الاصطناعي ومراقبتها، بما في ذلك تحميل البيانات وتنزيلها، وإنشاء البيانات أو تعديلها أو حذفها، وأي إجراءات قد تؤثر على السلامة أو السرية أو التوافر.
٢-٨-٣	حماية سجلات الذكاء الاصطناعي ذات الصلة بالأمن السيبراني والاحتفاظ بها وتحليلها؛ لدعم متابعة الالتزام والاستجابة للحوادث ومعالجة الثغرات والتحقيق فيها.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-8-1	تُحفظ سجلات أنظمة الذكاء الاصطناعي اثني عشر شهراً على الأقل، أو أكثر إذا اشترط العقد، مع مزامنة التوقيت من مصدر موحد.
QIS-2-8-2	تُرسل السجلات إلى مركز العمليات الأمنية المُدار، وتُعرَّف حالات كشف محددة للسلوكيات غير الطبيعية في أدوات الذكاء الاصطناعي.
QIS-2-8-3	يُمكَّن تتبع الأثر في مزايا الذكاء الاصطناعي بأنظمة العملاء، بحيث يُربط كل مخرج بمُدخله والمستخدم الذي طلبه وإصدار النموذج الذي أنتجه.

٩-٢ حماية تطبيقات الويب (Web Application Security)

الهدف: ضمان تصميم التطبيقات المدعومة بالذكاء الاصطناعي وواجهات برمجة التطبيقات وواجهات الويب والوكلاء والمكونات البرمجية وعمليات التكامل المرتبطة بها، وتطويرها وإعدادها وتشغيلها بصورة آمنة.

الرقم	الضوابط
٢-٩-١	حماية تطبيقات وخدمات الويب المرتبطة بأنظمة الذكاء الاصطناعي باستخدام بروتوكولات اتصال آمنة، وتحديد معدل الطلبات، والحماية من هجمات حجب الخدمة، ونقاط خروج متحكم بها، ومرشحات لحظر القنوات غير الآمنة.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-9-1	تُفصل واجهات الذكاء الاصطناعي المتاحة للمواطنين في أنظمة العملاء عن الواجهات الداخلية، وتُطبق سياسات مصادقة مختلفة لكل منهما.
QIS-2-9-2	يُظهر كل نظام عميل يتضمن ميزة ذكاء اصطناعي موجهة للمواطنين إشعاراً واضحاً بأنه يتعامل مع نظام ذكاء اصطناعي، وبحدود الاعتماد على مخرجاته.

٣ صمود الأمن السيبراني (Cybersecurity Resilience)

٣-١ جوانب صمود الأمن السيبراني في إدارة استمرارية الأعمال (Cybersecurity Resilience Aspects of BCM)

الهدف: ضمان توافر متطلبات صمود الأمن السيبراني في إدارة استمرارية أعمال الجهة، ومعالجة الآثار المترتبة على أنظمة الذكاء الاصطناعي نتيجة الكوارث الناتجة عن المخاطر السيبرانية، بما يتناسب مع أهميتها ومدى الاعتماد عليها.

الرقم	الضوابط
٣-١-١	تحديد إجراءات الرجوع إلى الإصدارات السابقة (Rollback) والإيقاف الآمن للتشغيل (Safe Shutdown) وتحديد البدائل لأنظمة الذكاء الاصطناعي عند وقوع حادثة أمن سيبراني، ما أمكن ذلك.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-3-1-1	يُضمَّن أثر تعطل مزايا الذكاء الاصطناعي في أنظمة العملاء ضمن تحليل أثر الأعمال في QIS-BCP-001، ويُحدد لكل منها زمن التعافي المستهدف ونقطة الاستعادة المستهدفة.
QIS-3-1-2	يُعد بديل تشغيلي يدوي لكل خدمة عميل تعتمد على الذكاء الاصطناعي، ويُختبر سنوياً.

٤ الأمن السيبراني المتعلق بالأطراف الخارجية (Third-Party Cybersecurity)

٤-١ الأمن السيبراني المتعلق بالأطراف الخارجية (Third-Party Cybersecurity)

الهدف: ضمان تحديد مخاطر الأمن السيبراني الناشئة عن جهات أو مكونات أو خدمات الأطراف الخارجية المستخدمة في دورة حياة الذكاء الاصطناعي، وتقييمها وإدارتها ومراقبتها باستمرار.

الرقم	الضوابط
٤-١-١	تقييم مخاطر الأمن السيبراني التي قد تنشأ من استخدام أطراف وجهات خارجية لأنظمة الذكاء الاصطناعي ومعالجتها.

الرقم	الضوابط
٤-١-٢	تقييم الأمن السيبراني لمكونات الذكاء الاصطناعي التابعة لجهات خارجية في أنظمة الذكاء الاصطناعي قبل الاستخدام وبشكل مستمر.
٤-١-٣	ضمان التزام مطوري الذكاء الاصطناعي بمتطلبات الأمن السيبراني للذكاء الاصطناعي الخاصة بالجهة بموجب العقود، ومراقبة هذا الالتزام وتقييمه دورياً.
٤-١-٤	تحديد متطلبات الخروج والنقل والتخلص أو الإتلاف الآمن لمكونات أنظمة الذكاء الاصطناعي عند تغيير المطور أو إنهاء العقد.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-4-1-1	يُقيَّم كل مزود أداة ذكاء اصطناعي قبل اعتماده في: موقع معالجة البيانات واستضافتها، ومدة الاحتفاظ بالمدخلات، والالتزام بعدم التدريب عليها، والضوابط الأمنية، وشروط العقد، ويُعاد التقييم سنوياً.
QIS-4-1-2	تُضمَّن عقود المزودين حق التدقيق والإشعار بالحوادث خلال مدة محددة، مع تقييم مخاطر التركز على مزود واحد.
QIS-4-1-3	تُعد خطة خروج موثقة لكل مزود تشمل استعادة البيانات ونقل الخدمة والتحقق من الإتلاف الآمن لدى المزود.

٩. المواءمة مع سياسة «الذكاء الاصطناعي أولاً»

صدرت سياسة «الذكاء الاصطناعي أولاً» عن الهيئة السعودية للبيانات والذكاء الاصطناعي للجهات العامة. والشركة ليست جهة عامة، لكنها تلتزم بمواءمة ممارساتها مع هذه السياسة لأن عملاءها جهات حكومية مخاطبة بها، ولأن العقود قد تشترط ذلك. وترد فيما يلي البنود المستمدة منها بأرقام موادها، وتليها في كل مادة متطلبات تنفيذية خاصة بالشركة تحمل الرمز QIS.

٩,١ مجالات التطبيق (المادة السادسة)

٩,١,١	تُعطى الأولوية في تطبيق نهج «الذكاء الاصطناعي أولاً» إلى المجالات التي يحقق فيها الذكاء الاصطناعي قيمة مضافة من حيث رفع الإنتاجية، أو زيادة الجودة، أو خفض التكاليف، أو تحسين تجربة المستفيد، ومنها: تخطيط الأعمال وتنظيم القوى العاملة مع بقاء دور المراجعة والاعتماد لدى العنصر البشري؛ وتصميم الخدمات وتطوير العمليات بما يستحضر إمكانات الذكاء الاصطناعي منذ مراحل التصميم الأولى؛ وتخطيط المشتريات والتعاقدات في حدود ما تجيزه الأنظمة.
٩,١,٢	للجهة تطبيق النهج في مجالات أخرى متى اتسق ذلك مع مبادئ السياسة، وثبتت ملاءمته وجدواه، وأمكن تحقيق قيمة مضافة مؤسسية واضحة.

٩,١,٣	لا يُقصد بمجالات التطبيق الاستخدامات الشكلية أو التجريبية التي لا ترتبط بقيمة مؤسسية واضحة، ولا مجرد اقتناء أدوات أو حلول تقنية دون توظيف فعلي أو أثر متحقق.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.1.1	تعتمد اللجنة الإشرافية قائمة سنوية بمجالات تطبيق الذكاء الاصطناعي ذات الأولوية في الشركة، مصنفة حسب القيمة المتوقعة ومستوى الجاهزية.
QIS-9.1.2	يُشترط لكل حالة استخدام مقترحة بيان مختصر بالمشكلة المستهدفة والبديل غير التقني والقيمة المتوقعة وكلفة التشغيل، وتُرفض الحالات التي لا يمكن قياس أثرها.

٩,٢ المبادئ (المادة السابعة)

٩,٢,١	تمكين الإنسان: أن يكون الإنسان محوراً للتحول، من خلال رفع وعي العاملين وتمكينهم من استخدام الذكاء الاصطناعي بفاعلية.
٩,٢,٢	القيمة قبل التقنية: يُعتمد الذكاء الاصطناعي متى ثبتت ملاءمته وجدواه مقارنة بالبدائل الأخرى، مع مراعاة كفاءة الموارد وتجنب التعقيد.
٩,٢,٣	التبني المتدرج: يُطبق الذكاء الاصطناعي بصورة متدرجة تبدأ بالمجالات الأكثر أولوية أو جاهزية، ثم تتوسع بحسب الاحتياجات والقدرات.
٩,٢,٤	الاستخدام المسؤول: يُراعى التوافق مع الأنظمة الوطنية لحوكمة الذكاء الاصطناعي، لضمان الاستخدام الآمن وحماية الحقوق والحد من الآثار السلبية.
٩,٢,٥	السيادة على البيانات: يُلتزم بالأنظمة الوطنية ذات الصلة بالبيانات والأمن السيبراني، بما يضمن حماية البيانات الوطنية ومعالجتها بصورة آمنة ومتوافقة.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.2.1	يُحتفظ بقرار بشري نهائي في كل عملية يترتب عليها أثر على المواطنين أو على التزامات العميل النظامية، ويُوثق اسم المعتمِد وتاريخ الاعتماد.
QIS-9.2.2	يبدأ تبني أي أداة أو ميزة جديدة بمرحلة تجريبية محددة النطاق والمدة ومعايير النجاح، ولا يُوسع نطاقها إلا بعد تحقق تلك المعايير.
QIS-9.2.3	تُعالج بيانات العملاء وتُخزن داخل المملكة، ويُوثق موقع المعالجة لكل أداة وخدمة.

٩,٣ الركائز (المادة الثامنة)

٩,٣,١	توجهات استراتيجية وتنظيمية: رؤية وأهداف واضحة تربط تبني الذكاء الاصطناعي بالأولويات المؤسسية، وأطر مؤسسية توضح الأدوار والمسؤوليات، ووحدة إدارية معنية بالذكاء الاصطناعي تتولى المتابعة الداخلية.

٩,٣,٢	ممكنات مؤسسية: كفاءات بشرية مناسبة، وبيانات مهيأة تتسم بالجودة والحوكمة مع حماية البيانات الشخصية في كامل دورة حياة النموذج، والاستفادة من البنى التحتية الوطنية للذكاء الاصطناعي.
٩,٣,٣	مخرجات عملية: تطبيقات تنتقل من التجربة إلى التطبيق المستدام، وأثر ملموس على الأداء يُقاس بمؤشرات مثل عدد حالات الاستخدام والأثر المتحقق.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.3.1	تتولى وحدة الحوكمة والمخاطر والالتزام دور الوحدة المعنية بالذكاء الاصطناعي وفق البند ٦,٢، وترفع تقاريرها الدورية إلى اللجنة الإشرافية.
QIS-9.3.2	يُشترط لاستخدام أي مجموعة بيانات في الذكاء الاصطناعي وجود مالك معرّف، ومستوى تصنيف، وموافقة على الغرض من الاستخدام، وموافقة العميل إذا كانت من بياناته.

٩,٤ آليات المتابعة (المادة التاسعة)

٩,٤,١	تتولى الوحدة الإدارية للذكاء الاصطناعي المتابعة الدورية لتطبيق السياسة وما يتصل بها من مبادرات وتطبيقات.
٩,٤,٢	يُعتمد في متابعة التقدم العام على المستوى الوطني على المؤشر الوطني للذكاء الاصطناعي.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.4.1	يُحتفظ بسجل مركزي لحالات الاستخدام والأدوات المعتمدة يتضمن الحالة والمالك وتاريخ آخر تقييم والأثر المقاس، وتُرفع تقارير المتابعة إلى اللجنة الإشرافية كل ثلاثة أشهر.

٩,٥ أحكام عامة (المادة العاشرة)

٩,٥,١	تُعد السياسة مكملة للأنظمة والقرارات والتعليمات النافذة، ولا تخل بها.
٩,٥,٢	تتكامل السياسة مع ما يصدر عن الهيئة والجهات المختصة من أطر وأدلة وأدوات ومؤشرات ذات صلة.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.5.1	تُحدَّث هذه السياسة خلال مدة لا تتجاوز تسعين يوماً من صدور أي تحديث نظامي أو تنظيمي وطني ذي أثر على أحكامها.
QIS-9.5.2	عند التعارض بين هذه السياسة وأي وثيقة داخلية أخرى أو متطلب تعاقدي لعميل، يُعمل بالنص الأكثر تشدداً في متطلبات الحماية، وتُرفع الحالة إلى اللجنة الإشرافية.

١٠. مؤشرات الأداء الرئيسية (KPIs) لاستخدام الذكاء الاصطناعي

الرمز	المؤشر	الهدف	التكرار
KPI-01	نسبة أدوات الذكاء الاصطناعي المستخدمة في الشركة والمدرجة في سجل الأدوات المعتمدة	١٠٠٪	ربع سنوي
KPI-02	نسبة الشيفرات المولدة بالذكاء الاصطناعي التي اجتازت المراجعة والفحص الأمني قبل الدمج	١٠٠٪	شهري
KPI-03	نسبة حوادث الذكاء الاصطناعي التي احتُويت ضمن المدة المحددة في QIS-PRC-002	٩٠٪	شهري
KPI-04	نسبة مزايا الذكاء الاصطناعي في أنظمة العملاء ذات تقييم مخاطر معتمد قبل التشغيل	١٠٠٪	شهري
KPI-05	نسبة الموظفين والمتعاقدين الذين أكملوا التدريب على هذه السياسة	٩٠٪	نصف سنوي
KPI-06	نسبة مزودي الأدوات المعتمدة الذين أعيد تقييمهم خلال الاثني عشر شهراً الماضية	١٠٠٪	ربع سنوي

١١. مؤشرات أداء المخاطر (KRIs) لاستخدام الذكاء الاصطناعي

مفتاح الألوان (RAG Status)

اللون	الحالة	المعنى والإجراء المطلوب
أخضر	**ضمن الهدف / مقبول**	المؤشر ضمن العتبة المقبولة، ويُستمر في المتابعة الروتينية.
أصفر	**يحتاج إلى انتباه**	تجاوز المؤشر الحد المقبول، ويتطلب متابعة فورية وتصحيحًا خلال الفترة المحددة.
أحمر	**خطر / عدم امتثال**	تجاوز المؤشر العتبة الحرجة، ويتطلب تصعيدًا فوريًا للإدارة العليا وخطة معالجة عاجلة.

الرمز	المؤشر	العتبة	التكرار
KRI-01	عدد خدمات الذكاء الاصطناعي غير المعتمدة المرصودة في حركة الشبكة	أخضر: ٠ · أصفر: من ١ إلى ٣ · أحمر: ٤ فأكثر	شهري
KRI-02	حالات إدخال بيانات عملاء أو بيانات شخصية في أدوات الذكاء الاصطناعي دون موافقة	أحمر: أي حالة	شهري
KRI-03	عدد الثغرات في مكونات الذكاء الاصطناعي التي لم تُعالج ضمن المدة المحددة	أصفر: ١ · أحمر: ٢ فأكثر	شهري
KRI-04	مزايا ذكاء اصطناعي تعمل في أنظمة العملاء دون تقييم مخاطر معتمد	أحمر: أي حالة	ربع سنوي
KRI-05	مفاتيح واجهات برمجة لم تُدوَّر خلال تسعين يوماً	أصفر: ١ · أحمر: ٢ فأكثر	شهري
KRI-06	قرارات تمس المواطنين اعتمدت على مخرجات الذكاء الاصطناعي دون إشراف بشري موثق	أحمر: أي حالة	ربع سنوي

١٢. عواقب عدم الامتثال

في حال عدم الالتزام بهذه السياسة قد يتعرض الموظف أو المتعاقد لإجراءات تأديبية وفق اللوائح الداخلية، تشمل الإنذار الرسمي، أو تقييد الصلاحيات أو سحبها، أو الإيقاف المؤقت، وقد تصل إلى إنهاء العلاقة الوظيفية أو التعاقدية. ويُعد إدخال بيانات العملاء أو البيانات الشخصية في أداة غير معتمدة حادثة بيانات تُعالج وفق خطة الاستجابة للحوادث QIS-IRP-001، وقد يترتب عليها مساءلة نظامية وفق نظام حماية البيانات الشخصية.

١٣. آلية التواصل

نوع الطلب / البلاغ	الجهة المسؤولة	آلية التواصل
الاستفسارات العامة عن السياسة	قائد الحوكمة والمخاطر والالتزام	grc@qis.example
طلب اعتماد أداة ذكاء اصطناعي جديدة	قائد الحوكمة والمخاطر والالتزام	نموذج الطلب وفق الإجراء الأول في QIS-PRC-002
الدعم الفني لأدوات الذكاء الاصطناعي	الرئيس التنفيذي للتقنية	نظام التذاكر
البلاغات الأمنية والحوادث	العمليات والهندسة الأمنية	security@qis.example — التحويلة ٢١٠٠

نوع الطلب / البلاغ	الجهة المسؤولة	آلية التواصل
استخدام الذكاء الاصطناعي في بيانات عميل أو نظامه	رئيس تقديم الخدمات	جهة الاتصال المحددة في العقد
طلب تدريب أو توعية	قائد الحوكمة والمخاطر والالتزام	grc@qis.example

١٤. المراجعة وتحديث السياسة

١٤٫١ مراجعة السياسة

يتولى قائد الحوكمة والمخاطر والالتزام مراجعة هذه السياسة كل ستة أشهر خلال السنة الأولى لتسارع تقنيات الذكاء الاصطناعي، ثم سنوياً، للتحقق من ملاءمتها وفعاليتها وتوافقها مع أهداف الشركة ومتطلبات عملائها.

١٤٫٢ تحديث السياسة

تُحدَّث هذه السياسة عند أي تغيير جوهري في خدمات الشركة أو عملائها أو أدواتها، أو عند وقوع حادثة ذات صلة، أو عند صدور متطلبات تشريعية أو تنظيمية جديدة، ومنها صدور الصيغة النهائية لإرشادات الأمن السيبراني للذكاء الاصطناعي.

١٥. المراجع

النوع	رمز المرجع	اسم المرجع	الجهة
خارجي	AICG-1:2026	إرشادات الأمن السيبراني للذكاء الاصطناعي — وثيقة إرشادية بُني عليها القسم ٨	الهيئة الوطنية للأمن السيبراني
خارجي	AI-First	سياسة «الذكاء الاصطناعي أولاً» — وثيقة توجيهية بُني عليها القسم ٩	الهيئة السعودية للبيانات والذكاء الاصطناعي
خارجي	ECC-2:2024	الضوابط الأساسية للأمن السيبراني	الهيئة الوطنية للأمن السيبراني
خارجي	PDPL	نظام حماية البيانات الشخصية ولائحته التنفيذية	الهيئة السعودية للبيانات والذكاء الاصطناعي
خارجي	—	مبادئ أخلاقيات الذكاء الاصطناعي	الهيئة السعودية للبيانات والذكاء الاصطناعي
خارجي	ISO/IEC 42001	نظام إدارة الذكاء الاصطناعي (٢٠٢٣)	المنظمة الدولية للتوحيد القياسي

النوع	رمز المرجع	اسم المرجع	الجهة
داخلي	QIS-PRC-002	إجراءات استخدام الذكاء الاصطناعي	QIS
داخلي	QIS-POL-001	سياسة حماية البيانات	QIS
داخلي	QIS-RMM-001	منهجية إدارة المخاطر	QIS
داخلي	QIS-IRP-001	خطة الاستجابة للحوادث السيبرانية	QIS
داخلي	QIS-CHR-001	ميثاق إدارة الأمن السيبراني وهيكلها التنظيمي	QIS

وثيقتا AICG-1:2026 و«الذكاء الاصطناعي أولاً» وثيقتان إرشاديتان، وإرشادات الهيئة الوطنية للأمن السيبراني ما زالت مشروعاً مطروحاً لاستطلاع الآراء. وقد اعتُمدتا أساساً لصياغة بنود هذه السياسة، على أن تُحدَّث عند صدور الصيغ النهائية. ونصوص الضوابط والمواد الواردة في القسمين ٨ و٩ تُطابق مع الوثائق الرسمية قبل اعتماد الإصدار ١٫٠.

مقيد